CyberDefenders

RESOLUCIÓN DE LABORATORIO

Lab: PsExec Hunt (CyberDefenders)

Análisis de tráfico SMB mediante Wireshark para identificar movimiento lateral con PsExec, uso de credenciales válidas, acceso a recursos administrativos y ejecución remota en sistemas comprometidos.

Sebastian David
Torres Reyes

Escenario:

Analizar el tráfico SMB en un PCAP utilizando Wireshark para identificar el movimiento lateral de PsExec, los sistemas comprometidos, las credenciales de usuario y los recursos compartidos administrativos.

Herramientas utilizadas:

- Wireshark

Resumen:

El incidente analizado detalla un ataque de movimiento lateral originado desde la dirección IP interna 10.0.0.130. El primer objetivo comprometido es el dispositivo con hostname Sales-PC (IP 10.0.0.133), donde el atacante se autenticó mediante el protocolo SMB2 utilizando las credenciales del usuario "ssales". La secuencia de ataque involucró el acceso inicial al recurso compartido IPC$ para establecer comunicación, seguido del acceso al recurso administrativo ADMIN$ para el despliegue y ejecución del binario PSEXESVC.exe, permitiendo así la ejecución remota de comandos. Posteriormente, la misma técnica de pivoteo fue empleada para comprometer un segundo sistema dentro de la red (IP 10.0.0.131). El análisis concluye que la intención operativa es obtener el control de múltiples equipos mediante movimiento lateral, dado que en el tráfico capturado no se evidencian técnicas de persistencia a largo plazo ni comunicación con servidores de comando y control (C&C).

P1: Para rastrear eficazmente las actividades del atacante dentro de nuestra red, ¿puede identificar la dirección IP de la máquina desde la que el atacante obtuvo acceso inicialmente?

R: 10.0.0.130

Se observó que la dirección IP 10.0.0.130 inició una conexión TCP (three-way handshake) hacia 10.0.0.133 sobre el puerto 445 (SMB). Posteriormente, se identificó tráfico SMB2 asociado a autenticación y acceso a recursos compartidos, lo que indica actividad remota sobre el sistema destino.

Source	Src Port	Destination	Dst. Port	Protocol	Length	Info
10.0.0.132	53204	10.0.0.1	53	TCP	78	53204 → 53 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=8164
10.0.0.130	49696	10.0.0.133	445	TCP	66	49696 → 445 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
10.0.0.133	445	10.0.0.130	49696	TCP	66	445 → 49696 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 WS=256 S
10.0.0.130	49696	10.0.0.133	445	TCP	60	49696 → 445 [ACK] Seq=1 Ack=1 Win=2102272 Len=0
10.0.0.130	49696	10.0.0.133	445	SMB	127	Negotiate Protocol Request
10.0.0.133	445	10.0.0.130	49696	SMB2	506	Negotiate Protocol Response
10.0.0.130	49696	10.0.0.133	445	SMB2	286	Negotiate Protocol Request
10.0.0.133	445	10.0.0.130	49696	SMB2	590	Negotiate Protocol Response
10.0.0.130	49696	10.0.0.133	445	SMB2	220	Session Setup Request, NTLMSSP_NEGOTIATE
10.0.0.133	445	10.0.0.130	49696	SMB2	329	Session Setup Response, Error: STATUS_MORE_PROCESSING_REQUIRED, NTLM
10.0.0.130	49696	10.0.0.133	445	SMB2	595	Session Setup Request, NTLMSSP_AUTH, User: \ssales
10.0.0.133	445	10.0.0.130	49696	SMB2	159	Session Setup Response
10.0.0.130	49696	10.0.0.133	445	SMB2	164	Tree Connect Request, Tree: '\\10.0.0.133\IPC$'
10.0.0.133	445	10.0.0.130	49696	SMB2	138	Tree Connect Response, Tree: '\\10.0.0.133\IPC$'
10.0.0.130	49696	10.0.0.133	445	SMB2	178	Ioctl Request FSCTL_QUERY_NETWORK_INTERFACE_INFO
10.0.0.133	445	10.0.0.130	49696	SMB2	474	Ioctl Response FSCTL_QUERY_NETWORK_INTERFACE_INFO
10.0.0.130	49696	10.0.0.133	445	SMB2	168	Tree Connect Request, Tree: '\\10.0.0.133\ADMIN$'
10.0.0.133	445	10.0.0.130	49696	SMB2	138	Tree Connect Response, Tree: '\\10.0.0.133\ADMIN$'
10.0.0.130	49696	10.0.0.133	445	SMB2	234	Create Request, File: <share>

P2: Para comprender completamente el alcance de la brecha, ¿puede determinar el nombre de host de la máquina a la que el atacante se conectó inicialmente?

R: Sales-PC

Se analizó el flujo TCP de los paquetes SMB2. Se visualizaron las cabeceras SMB y la referencia cifs/10.0.0.133, lo que indica acceso a recursos compartidos del sistema. Adicionalmente, se observó repetidamente el hostname “Sales-PC”, confirmando la identidad del host destino.

P3: Conocer el nombre de usuario de la cuenta que el atacante utilizó para autenticarse nos permitirá comprender el alcance de la brecha de seguridad. ¿Cuál es el nombre de usuario que utilizó el atacante para autenticarse?

R: ssales

Se analizaron los paquetes SMB2 en el panel de detalles, donde se identificó el nombre de usuario “ssales” asociado a la sesión autenticada.

```
▼ Session Id: 0x0000300000000039 Acct:ssales Domain: Host:HR-PC
    [Account: ssales]
    [Domain: ]
    [Host: HR-PC]
    [Authenticated in Frame: 133]
```

10.0.0.133	445	10.0.0.130	49696	SMB2	590	Negotiate Protocol Response
10.0.0.130	49696	10.0.0.133	445	SMB2	220	Session Setup Request, NTLMSSP_NEGOTIATE
10.0.0.133	445	10.0.0.130	49696	SMB2	329	Session Setup Response, Error: STATUS_MORE_PROCESSING_REQUIRED, NTLMSSP_CH
10.0.0.130	49696	10.0.0.133	445	SMB2	595	Session Setup Request, NTLMSSP_AUTH, User: \ssales
10.0.0.133	445	10.0.0.130	49696	SMB2	159	Session Setup Response
10.0.0.130	49696	10.0.0.133	445	SMB2	164	Tree Connect Request, Tree: '\\10.0.0.133\IPC$'

P4: Tras determinar cómo se movió el atacante dentro de nuestra red, necesitamos saber qué hizo en la máquina objetivo. ¿Cuál es el nombre del archivo ejecutable del servicio que el atacante instaló en la máquina objetivo?

R: PSEXESVC.exe

Tras la autenticación, el atacante accede al recurso administrativo ADMIN$ y transfiere el binario “PSEXESVC.exe”, el cual es utilizado por PsExec para crear un servicio remoto y ejecutar comandos en el sistema 10.0.0.133.

Source	Src Port	Destination	Dst. Port	Protocol	Length	Info
10.0.0.133	445	10.0.0.130	49696	SMB2	506	Negotiate Protocol Response
10.0.0.130	49696	10.0.0.133	445	SMB2	286	Negotiate Protocol Request
10.0.0.133	445	10.0.0.130	49696	SMB2	590	Negotiate Protocol Response
10.0.0.130	49696	10.0.0.133	445	SMB2	220	Session Setup Request, NTLMSSP_NEGOTIATE
10.0.0.133	445	10.0.0.130	49696	SMB2	329	Session Setup Response, Error: STATUS_MORE_PROCESSING_REQUIRED, NTLMSSP
10.0.0.130	49696	10.0.0.133	445	SMB2	595	Session Setup Request, NTLMSSP_AUTH, User: \ssales
10.0.0.133	445	10.0.0.130	49696	SMB2	159	Session Setup Response
10.0.0.130	49696	10.0.0.133	445	SMB2	164	Tree Connect Request, Tree: '\\10.0.0.133\IPC$'
10.0.0.133	445	10.0.0.130	49696	SMB2	138	Tree Connect Response, Tree: '\\10.0.0.133\IPC$'
10.0.0.130	49696	10.0.0.133	445	SMB2	178	Ioctl Request FSCTL_QUERY_NETWORK_INTERFACE_INFO
10.0.0.133	445	10.0.0.130	49696	SMB2	474	Ioctl Response FSCTL_QUERY_NETWORK_INTERFACE_INFO
10.0.0.130	49696	10.0.0.133	445	SMB2	168	Tree Connect Request, Tree: '\\10.0.0.133\ADMIN$'
10.0.0.133	445	10.0.0.130	49696	SMB2	138	Tree Connect Response, Tree: '\\10.0.0.133\ADMIN$'
10.0.0.130	49696	10.0.0.133	445	SMB2	234	Create Request, File: <share>
10.0.0.133	445	10.0.0.130	49696	SMB2	298	Create Response, File: <share>
10.0.0.130	49696	10.0.0.133	445	SMB2	146	Close Request, File: <share>
10.0.0.133	445	10.0.0.130	49696	SMB2	182	Close Response, File: <share>
10.0.0.130	49696	10.0.0.133	445	SMB2	382	Create Request, File: PSEXESVC.exe
10.0.0.133	445	10.0.0.130	49696	SMB2	410	Create Response, File: PSEXESVC.exe

P5: Necesitamos saber cómo el atacante instaló el servicio en la máquina comprometida para comprender sus tácticas de movimiento lateral. Esto puede ayudar a identificar otros sistemas afectados. ¿Qué recurso compartido de red utilizó PsExec para instalar el servicio en la máquina objetivo?

R: ADMIN$

Se observó el acceso al recurso compartido administrativo ADMIN$, el cual permite la transferencia de archivos al sistema remoto. Este recurso fue utilizado para desplegar y ejecutar el archivo PSEXESVC.exe, y habilitar la ejecución remota de comandos con privilegios de SYSTEM.

10.0.0.130	49696	10.0.0.133	445	SMB2	168	Tree Connect Request, Tree: '\\10.0.0.133\ADMIN$'
10.0.0.133	445	10.0.0.130	49696	SMB2	138	Tree Connect Response, Tree: '\\10.0.0.133\ADMIN$'
10.0.0.130	49696	10.0.0.133	445	SMB2	234	Create Request, File: <share>
10.0.0.133	445	10.0.0.130	49696	SMB2	298	Create Response, File: <share>
10.0.0.130	49696	10.0.0.133	445	SMB2	146	Close Request, File: <share>
10.0.0.133	445	10.0.0.130	49696	SMB2	182	Close Response, File: <share>
10.0.0.130	49696	10.0.0.133	445	SMB2	382	Create Request, File: PSEXESVC.exe
10.0.0.133	445	10.0.0.130	49696	SMB2	410	Create Response, File: PSEXESVC.exe

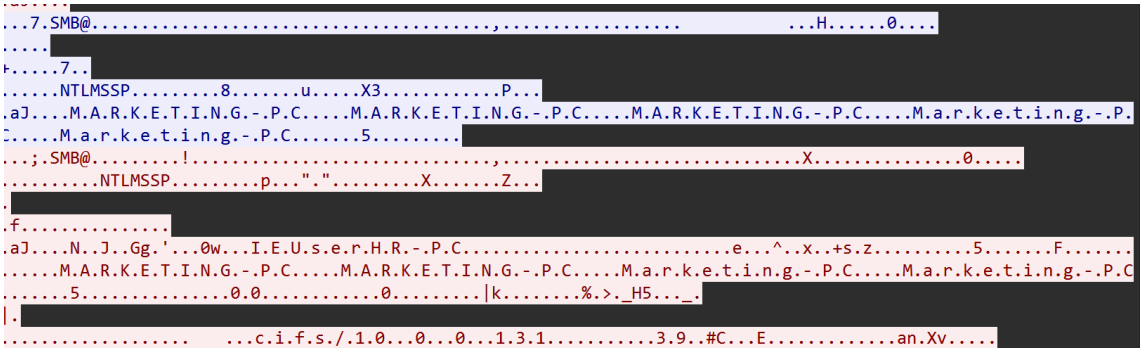
P6: Debemos identificar el recurso compartido de red utilizado para la comunicación entre las dos máquinas. ¿Qué recurso compartido de red utilizó PsExec para la comunicación?

R: IPC$

Antes de que el atacante acceda al recurso compartido ADMIN$ accedió al recurso compartido IPC$, el cual es utilizado por SMB para la comunicación entre procesos y la gestión de sesiones, siendo un paso previo a la autenticación y acceso a otros recursos como ADMIN$.

10.0.0.130	49696	10.0.0.133	445	SMB2	164	Tree Connect Request, Tree: '\\10.0.0.133\IPC$'
10.0.0.133	445	10.0.0.130	49696	SMB2	138	Tree Connect Response, Tree: '\\10.0.0.133\IPC$'
10.0.0.130	49696	10.0.0.133	445	SMB2	178	Ioctl Request FSCTL_QUERY_NETWORK_INTERFACE_INFO
10.0.0.133	445	10.0.0.130	49696	SMB2	474	Ioctl Response FSCTL_QUERY_NETWORK_INTERFACE_INFO

P7: Ahora que tenemos una idea más clara de las actividades del atacante en la máquina comprometida, es importante identificar cualquier movimiento lateral posterior. ¿Cuál es el nombre de host de la segunda máquina que el atacante utilizó como punto de pivote dentro de nuestra red?

R: MARKETING-PC

Se observó que la dirección IP 10.0.0.130 estableció conexiones SMB adicionales hacia la dirección IP 10.0.0.131, lo que indica un segundo intento de movimiento lateral dentro de la red. Mediante el análisis del tráfico SMB2 y el seguimiento de la sesión TCP, se identificó el hostname del sistema destino como “MARKETING-PC”, confirmando su uso como segundo objetivo en la cadena de ataque.